

Durcissement Cryptographique (TLS et SSH)

Durcissement de la configuration OpenSSH (Linux)

Pour éviter de corrompre le fichier principal `/etc/ssh/sshd_config`, nous allons utiliser la directive d'inclusion native d'Ubuntu en créant un fichier de configuration dédié. Ce fichier sera lu en priorité par le service SSH.

1. Connectez-vous sur le serveur **Ubuntu** avec le compte `formation` (ou un compte `sudoer`).

Créez un fichier de configuration personnalisé spécifiquement pour le durcissement cryptographique :

```
sudo nano /etc/ssh/sshd_config.d/99-crypto-hardening.conf
```

- 2.

Insérez les trois lignes suivantes (qui imposent les courbes elliptiques, GCM, ChaCha20 et SHA-2) :

```
KexAlgorithms curve25519-sha256,curve25519-sha256@libssh.org
```

```
Ciphers chacha20-poly1305@openssh.com,aes256-gcm@openssh.com
```

```
MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com
```

- 3.

4. Enregistrez et fermez le fichier (**CTRL+O**, **Entrée**, **CTRL+X**).

Avant de redémarrer, vérifiez la validité syntaxique globale du service SSH. Si cette commande renvoie une erreur, NE REDÉMARREZ PAS le service, corrigez le fichier.

```
sudo sshd -t
```

5. *(Si aucune erreur ne s'affiche, la syntaxe est parfaite).*

Appliquez les modifications en redémarrant le service :

```
sudo systemctl restart ssh
```

- 6.

Validez que le service tourne correctement après le redémarrage :

```
sudo systemctl status ssh
```

7.

Durcissement de l'API Schannel (Windows Server)

La modification manuelle de la base de registre est source d'erreurs (fautes de frappe, mauvais type de clé). Nous allons exécuter un bloc PowerShell qui créera proprement l'arborescence requise et forcera la désactivation des protocoles vulnérables.

1. Connectez-vous sur la machine **Windows Server**.
2. Ouvrez une console **Windows PowerShell en tant qu'Administrateur**.

Copiez et collez l'intégralité de ce bloc de code dans la console, puis appuyez sur **Entrée** :

```
$SchannelPath =
```

```
"HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols"
```

```
# Définition de la matrice de sécurité (Désactivation des vieux, Activation de TLS 1.2)
```

```
$Protocols = @{
```

```
    "SSL 3.0" = $false
```

```
    "TLS 1.0" = $false
```

```
    "TLS 1.1" = $false
```

```
    "TLS 1.2" = $true
```

```
}
```

```
# Application de la matrice
```

```
foreach ($Protocol in $Protocols.GetEnumerator()) {
```

```
    ProtoPath = "SchannelPath\(Protocol.Name)"
```

```
    ServerPath = "ProtoPath\Server"
```

```
    ClientPath = "ProtoPath\Client"
```

```
# Création des clés si elles n'existent pas
```

```

if (-not (Test-Path $ServerPath)) { New-Item -Path $ServerPath -Force | Out-Null }

if (-not (Test-Path $ClientPath)) { New-Item -Path $ClientPath -Force | Out-Null }


# Configuration des valeurs DWORD

if ($Protocol.Value -eq $true) {

    Set-ItemProperty -Path $ServerPath -Name "Enabled" -Value 1 -Type DWord -Force

    Set-ItemProperty -Path $ServerPath -Name "DisabledByDefault" -Value 0 -Type DWord -Force

    Set-ItemProperty -Path $ClientPath -Name "Enabled" -Value 1 -Type DWord -Force

    Set-ItemProperty -Path $ClientPath -Name "DisabledByDefault" -Value 0 -Type DWord -Force

} else {

    Set-ItemProperty -Path $ServerPath -Name "Enabled" -Value 0 -Type DWord -Force

    Set-ItemProperty -Path $ServerPath -Name "DisabledByDefault" -Value 1 -Type DWord -Force

    Set-ItemProperty -Path $ClientPath -Name "Enabled" -Value 0 -Type DWord -Force

    Set-ItemProperty -Path $ClientPath -Name "DisabledByDefault" -Value 1 -Type DWord -Force

}

}

Write-Host "Configuration Schannel terminée avec succès." -ForegroundColor Green

```

3.

ÉTAPE CRITIQUE : Les modifications de la couche Schannel s'opérant au niveau du noyau de Windows (Ring 0), le service ne peut pas être simplement redémarré. **Le redémarrage du serveur est obligatoire.**

```
Restart-Computer -Force
```

4.

Validation de la posture cryptographique (Audit réseau)

L'audit s'effectue depuis la machine **Linux** vers elle-même, puis vers la machine Windows, afin de vérifier ce que les services exposent réellement sur le réseau (La vue de l'attaquant).

Sur la machine **Linux**, installez le scanner Nmap (s'il n'est pas déjà présent) :

```
sudo apt-get update && sudo apt-get install nmap -y
```

1.

Audit de la machine Linux (Port 22 - SSH) :

```
nmap -sV -p 22 --script ssh2-enum-algos 127.0.0.1
```

2. *Analyse du résultat* : L'onglet **encryption_algorithms** ne doit afficher **QUE** **chacha20-poly1305** et **aes256-gcm**. L'algorithme d'échange de clés (**kex_algorithms**) ne doit afficher **QUE** **curve25519**. Toute référence à **3des**, **aes128-cbc** ou **sha1** a définitivement disparu.

Audit de la machine Windows (Port 3389 - RDP/Schannel) : (Remplacez

<IP_WINDOWS_SERVER> par l'adresse IP réelle de votre serveur Windows).

```
nmap -sV -p 3389 --script ssl-enum-ciphers <IP_WINDOWS_SERVER>
```

3. *Analyse du résultat* : Nmap testera tous les protocoles. La sortie doit indiquer que les requêtes en **SSLv3**, **TLSv1.0** et **TLSv1.1** ont été rejetées (ou n'apparaissent pas). Seul le bloc **TLSv1.2** doit être listé avec une note de sécurité (Lettre A ou B).

Dépannage (Rollback en cas d'incident)

Si un problème de compatibilité majeur survient, voici les procédures d'annulation.

Annulation sur Linux (SSH) : Il suffit de supprimer le fichier de surcharge et de recharger le service.

```
sudo rm /etc/ssh/sshd_config.d/99-crypto-hardening.conf
```

```
sudo systemctl restart ssh
```

Annulation sur Windows (Schannel) : En PowerShell Administrateur, forcez la réactivation du protocole TLS 1.0 (souvent responsable des anciens problèmes de compatibilité applicative), puis redémarrez.

```
Set-ItemProperty -Path
```

```
"HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server" -Name "Enabled" -Value 1 -Type DWord -Force
```

```
Restart-Computer -Force
```